

Proportionate AI Governance for Resource-Constrained Organizations

Sep 18, 2026 · [@andrewmangle](#) andy@bestentrust.com

Abstract

Small and mid-size regulated organizations are adopting generative and predictive AI faster than they can govern it, and the dominant governance frameworks assume a compliance function that most lack. NIST AI RMF 1.0, ISO/IEC 42001, and COBIT 2019 presume dedicated roles, continuous monitoring, and formal inventories that a 12-attorney law firm, a 60-person healthcare nonprofit, or a community lender cannot staff. The result is either no AI policy or a boilerplate policy that creates liability by asserting controls that the organization does not operate.

This paper proposes a Proportionate AI Governance Model that scales obligations to two variables: the organization's AI exposure (what AI is actually doing) and its compliance capacity (who is available to govern it). The model defines three cumulative tiers, each with a minimum viable control set, an accountability assignment, and an explicit expectation for audit evidence. A crosswalk maps every control to NIST AI RMF subcategories, ISO/IEC 42001 clauses, COBIT objectives, and illustrative sector regulator expectations so that partial coverage is stated honestly and survives audit. Using a design science approach, the model is applied at recruited pilot organizations that match its target profiles: small law firms, mid-size healthcare nonprofits, and community financial institutions. The contribution is a governance artifact that a non-technical administrator can implement at the baseline tier in about one week, that grows with exposure rather than headcount, and that positions verification (rather than assertion) as the standard for AI trust even at a small scale.

1. Introduction: the compliance gap in small regulated organizations

The organizations most exposed to AI liability are the ones least equipped to manage it. A solo practitioner using an AI drafting assistant on privileged documents, a behavioral health nonprofit piloting an ambient clinical scribe, and a credit union using AI-assisted document intake all handle regulated data and all face regulator, insurer, and client expectations that an AI policy exists. None of them has an AI officer.

Three forces create the gap. First, adoption is bottom-up: staff bring consumer AI tools into their workflows before leadership has made any decisions. Second, the frameworks available to leadership were written for enterprises. NIST AI RMF 1.0 organizes 72 subcategories across four functions; ISO/IEC 42001 requires a management system with documented clauses for context, leadership, planning, support, operation, evaluation, and improvement; COBIT 2019 assumes an IT governance function. Third, the pressure to have something on paper is immediate. State bar ethics opinions on generative AI, HIPAA enforcement, state AI statutes governing consequential decisions, and cyber insurance questionnaires all now ask whether AI use is governed.

The common response is a downloaded template. Templates fail in a specific way: they assert controls ("all AI systems are inventoried and risk-assessed annually") that the organization does not perform. In an audit, a breach investigation, or a malpractice claim, an asserted-but-unperformed control is worse than an honest gap, because it converts a resource limitation into a misrepresentation.

This paper asks a practical question: what is the minimum governance structure that (a) a small regulated organization can operate, (b) scales up as AI exposure increases, and (c) maps traceably to the frameworks an auditor, regulator, or insurer will reference? The answer is a proportionate model in which obligations follow risk to people rather than organizational size, and in which every control is stated only if it is performed.

The paper proceeds as follows. Section 2 analyzes why the major frameworks do not fit at the small scale, using an auditor's lens. Section 3 presents the Proportionate Governance Model, its placement rule, and its three tiers. Section 4 provides the crosswalk. Section 5 describes the design science validation. Section 6 discusses measurement, verification, and limitations. Appendix A provides the Tier 1 acceptable use policy template as a reusable artifact.

2. Why existing frameworks do not fit

The major frameworks are sound. They do not fit small regulated organizations because each embeds capacity assumptions that are invisible to their authors and fatal to their adopters.

Framework	Implicit capacity assumption	What breaks at 30 people
NIST AI RMF 1.0	A governance function that can maintain policies, inventories, impact assessments, and measurement across 72 subcategories	No one owns MEASURE. Metrics, test plans, and drift monitoring have no operator, so the organization either skips the function or falsely claims it
ISO/IEC 42001	A management system with documented scope, leadership commitment, internal audit, and management review cycles	The management system overhead (Clauses 4 through 10) exceeds the AI use it governs. Internal audit (9.2) has no independent auditor
COBIT 2019	An IT governance layer separate from operations, with defined process owners for APO, BAI, DSS, and MEA domains	The managing partner is the IT owner, the process owner, and the user. Separation of duties does not exist
EU AI Act and U.S. state AI laws	Deployer obligations including impact assessments and human oversight for high-risk or consequential systems	Obligations are correctly risk-based but arrive without an implementation path sized for a deployer with no compliance staff

Three observations follow from reading these as an auditor rather than as a consultant.

The frameworks conflate scale with risk. A 12-person firm using AI to rank loan applicants creates more risk to individuals than a 500-person firm using AI to summarize meetings. The frameworks' control density tracks organizational maturity, not the consequence of the AI's decisions. A proportionate model must invert this and let exposure, not headcount, set the obligation.

Partial adoption is undefined. None of the frameworks describes what honest partial coverage looks like. An organization that operates 15 of 72 NIST subcategories has no vocabulary for saying so. Certification schemes are binary. This pushes small organizations toward either silence or overclaiming.

Evidence expectations are unstated at the low end. The frameworks describe what to do, not what a reasonable record of having done it looks like for an organization with no GRC tooling. A screenshot of a vendor's data retention terms, saved to a shared folder with a date, is legitimate audit evidence. The frameworks never say so, and small organizations do not know it counts.

The Proportionate Governance Model addresses all three: exposure drives tier placement, each tier states its coverage explicitly, and each control names its evidence.

3. The Proportionate Governance Model

The model places an organization in one of three cumulative tiers using two variables, then assigns a minimum viable control set to each tier. Obligations follow exposure. Capacity only determines how the controls are staffed, never whether they apply.

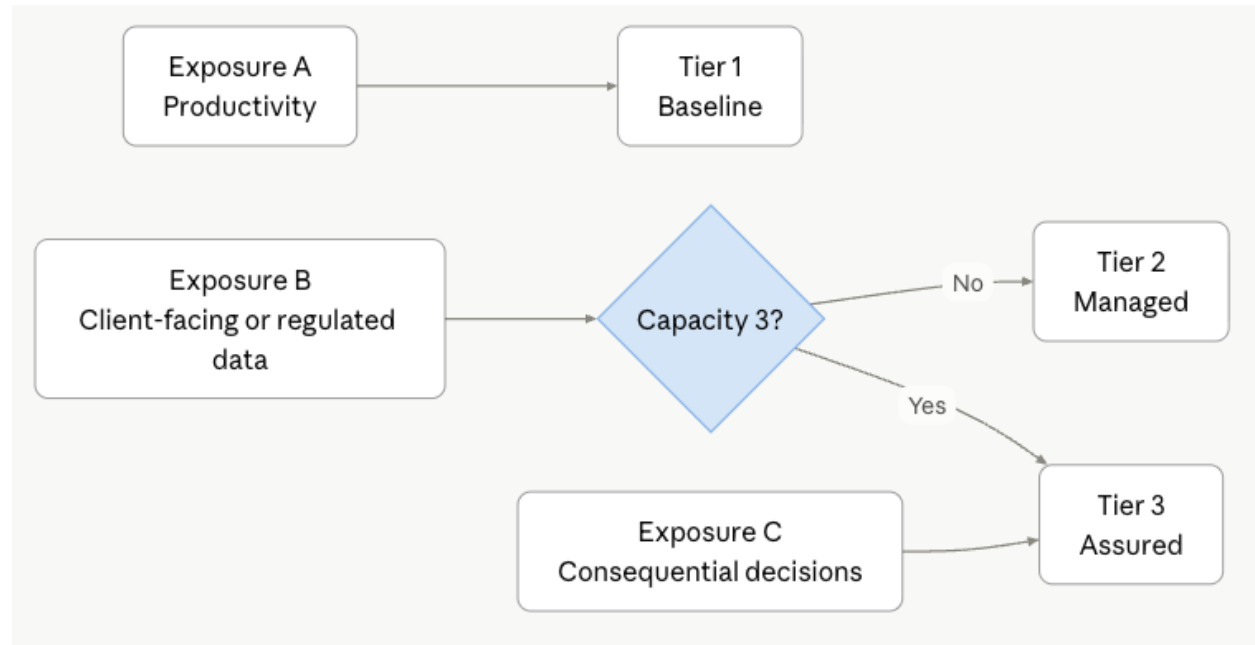
3.1 Placement rule

Exposure answers: what is AI actually doing here?

- **A. Productivity.** Drafting, summarizing, research assistance. A human reviews every output before it leaves the organization.
- **B. Client-facing or regulated data.** AI produces outputs seen by clients or patients, or AI processes regulated data (PHI, privileged material, nonpublic personal information).
- **C. Consequential decisions.** AI scores, ranks, recommends, or decides outcomes for individuals: eligibility, credit, hiring, clinical triage, case strategy, pricing.

Capacity answers: who is available to govern it?

1. No dedicated role. The owner, managing partner, executive director, or office manager carries compliance.
2. Part-time lead. An IT lead, practice manager, or privacy officer with compliance as one of several duties.
3. Named officer. A compliance, privacy, or security officer whose role includes governance.



Exposure C is Tier 3 regardless of capacity. Exposure A is Tier 1 regardless of capacity. Exposure B is Tier 2 unless the organization already has a named officer, in which case an auditor will reasonably expect Tier 3. Exposure overrides capacity; capacity never lowers a tier. That asymmetry is the model's central claim: a small organization making consequential decisions about people owes those people the same governance a large one does, and the model's job is to make that achievable, not to excuse it.

3.2 The three tiers

Tiers are cumulative. Tier 2 includes every Tier 1 control; Tier 3 includes every Tier 2 control. An organization claims only the tier it operates.

Control area	Tier 1: Baseline	Tier 2: Managed	Tier 3: Assured
Typical organization	8-attorney firm using an AI drafting assistant; small nonprofit drafting grants with a chatbot	60-person behavioral health nonprofit with an ambient scribe and a patient chatbot; regional lender using AI for document intake	Any organization where AI scores, ranks, or recommends outcomes for individuals
Accountability	One named AI owner (managing partner or ED is fine). No committee	Named AI owner plus a second reviewer from a different function	AI governance lead with documented authority; periodic review by leadership or board
Inventory	One-page list: approved tools, data	Adds purpose, data classification, vendor,	Adds risk rating per use case and a decision log

Control area	Tier 1: Baseline	Tier 2: Managed	Tier 3: Assured
	each may see, who approved	renewal and review date per tool	for anything touching individuals
Policy	Two-page acceptable use policy: approved tools, prohibited data, human review, disclosure rules (Appendix A)	Adds role-specific rules, client or patient disclosure language, incident reporting, vendor intake step	Adds impact assessment requirement, bias and accuracy testing, appeal or human override path for affected individuals
Risk assessment	Annual 10-question self-assessment, one page	Use-case assessment before adopting any Exposure B tool	Formal AI impact assessment per consequential use case, reviewed annually and on material change
Vendor management	Confirm data retention and training-use terms; keep the screenshot or contract clause	Written vendor questionnaire; BAA or equivalent where regulated data flows; data processing terms on file	Vendor attestation of model documentation, testing, and incident notification; right to audit or equivalent assurance
Human oversight	No AI output leaves the organization without human review	Defined review checkpoints by use case; named reviewer per workflow	Documented human decision authority; AI advisory unless explicitly approved; override rates monitored
Training	30-minute onboarding and annual refresher, attendance recorded	Role-based training; reviewers trained on failure modes of their tools	Governance lead trained on impact assessment and testing; annual leadership briefing
Incident handling	AI misuse folded into existing incident or HR process	Defined AI incident categories with reporting path	Root cause review, affected-party notification analysis, reporting to leadership
Monitoring	Quarterly spot check of tool list and usage	Semiannual review of inventory, incidents, vendor changes	Ongoing performance and drift review; annual independent

Control area	Tier 1: Baseline	Tier 2: Managed	Tier 3: Assured
			review
Audit evidence	Policy, inventory, self-assessment, training log	Adds assessments, vendor files, incident log, review minutes	Adds impact assessments, test results, decision logs, override data, independent review report
Effort to stand up	About 1 week, one person	4 to 6 weeks, part-time	8 to 12 weeks, with external help

3.3 Design principles

State only what is performed. Every tier's policy language describes controls the organization actually operates. Tier 1 does not claim monitoring it does not do. This is the single most important difference from a downloaded template.

Evidence is named, not implied. Each control specifies what record proves it happened. For Tier 1, that record can be a dated PDF in a shared folder.

Growth is by exposure, not by ambition. An organization moves up a tier when its AI use changes, not when it feels it should look more mature. This keeps the model honest and keeps effort proportionate.

4. Crosswalk

Every control area in the model maps to named provisions in the three major frameworks and to illustrative sector expectations. The crosswalk is what makes honest partial coverage defensible: a Tier 1 organization can point to exactly which subcategories it operates and which it does not.

Control area	NIST AI RMF 1.0	ISO/IEC 42001	COBIT 2019	Sector expectation (illustrative)
Accountability and roles	GOVERN 2.1, 2.2	Cl. 5.1, 5.3; Annex A.3	APO01	HIPAA Security Rule designated security official (45 CFR 164.308(a)(2)); state bar opinions place supervisory duty on the responsible lawyer
Inventory	MAP 1.1, 1.6;	Annex A.4, A.6.2	BAI09	Model inventory

Control area	NIST AI RMF 1.0	ISO/IEC 42001	COBIT 2019	Sector expectation (illustrative)
	GOVERN 1.4			is standard in financial regulator model risk guidance
Policy and acceptable use	GOVERN 1.1, 1.2	Cl. 5.2; Annex A.2	APO01, DSS05	ABA Formal Opinion 512 (2024) on generative AI competence, confidentiality, and disclosure
Risk and impact assessment	MAP 1.5, 3.1; MEASURE 2.6	Cl. 6.1; Annex A.5	APO12	HIPAA risk analysis (164.308(a)(1)); Colorado AI Act impact assessment duties for high-risk systems; NAIC AI model bulletin for insurers
Data handling	MAP 2.1; GOVERN 1.7	Annex A.7	APO14, DSS06	HIPAA minimum necessary and BAA requirements; attorney confidentiality rules; GLBA Safeguards Rule
Vendor and third party	GOVERN 6.1, 6.2	Annex A.10	APO10	HIPAA BAA; OCC and FDIC third-party risk guidance; bar duty to vet technology vendors
Human oversight	MANAGE 2.4;	Annex A.9.2, A.9.3	DSS01	Colorado AI Act and similar

Control area	NIST AI RMF 1.0	ISO/IEC 42001	COBIT 2019	Sector expectation (illustrative)
	GOVERN 3.2			statutes require human review and appeal for consequential decisions
Transparency and disclosure	GOVERN 4.1; MAP 5.1	Annex A.8	APO08	Client disclosure under bar opinions; patient notice under state chatbot and AI disclosure laws
Training and awareness	GOVERN 2.2, 4.2	Cl. 7.2, 7.3	APO07	HIPAA workforce training (164.308(a)(5)); bar competence duty
Incident management	MANAGE 4.1, 4.3	Cl. 10; Annex A.6.2.8	DSS02	HIPAA breach notification; state breach laws; regulator incident reporting where applicable
Monitoring and review	MEASURE 2.4, 2.7; MANAGE 4.2	Cl. 9.1, 9.2, 9.3	MEA01, MEA02	Model performance monitoring in financial model risk guidance
Bias and accuracy testing (Tier 3 only)	MEASURE 2.3, 2.11	Annex A.6.2.4, A.6.2.6	BAI03	Colorado AI Act; NYC Local Law 144 (automated employment decision tools); EEOC guidance on AI in employment

4.1 Coverage by tier

Tier	NIST AI RMF functions substantially covered	Functions explicitly not claimed
Tier 1	GOVERN (partial), MAP (partial)	MEASURE, MANAGE beyond incident handling
Tier 2	GOVERN, MAP, MANAGE (partial)	MEASURE beyond use-case assessment
Tier 3	GOVERN, MAP, MEASURE, MANAGE	None; independent review is the remaining gap versus certification

The "not claimed" column is the paper's most practical contribution. Stating what is not covered is what distinguishes a proportionate posture from an overclaimed one.

4.2 Verification note

Subcategory and clause numbers should be verified against the current NIST AI RMF Playbook and the published ISO/IEC 42001 text before submission. The sector column will date fastest; state AI statutes are changing on a months-long cycle, and the paper should cite the versions in force at submission and frame the column as examples of regulator expectations rather than a compliance guarantee.

5. Validation approach

The model is validated through design science research (Hevner et al., 2004; Peffers et al., 2007): build the artifact, apply it in real organizational settings, evaluate against stated objectives, and refine. This is the appropriate method because the contribution is a governance artifact whose value is its usability at small scale, not a causal claim.

5.1 Evaluation objectives

1. **Implementability.** Can a non-technical administrator stand up Tier 1 in about one week using only the policy template and inventory form?
2. **Honesty.** Does the resulting documentation describe only controls the organization performs?
3. **Traceability.** Can each control be mapped to a framework provision an auditor or insurer would recognize?
4. **Proportionality.** Does the tier assignment match the organization's actual exposure, and does moving up a tier feel justified rather than bureaucratic?

5.2 Case sites

Three anonymized organizations drawn from the model's target customer profiles rather than from the author's existing client base. Sites are recruited as volunteer pilots: each receives a free Tier 1 or Tier 2 stand-up in exchange for participation, which keeps the study independent of client relationships and tests the model on exactly the organizations most likely to adopt it. Sites are selected to span the three exposure levels and at least two sectors. Recruitment channels: professional association lists (state bar

practice management sections, state nonprofit associations, community banking and credit union leagues) and inbound response to the published Tier 1 template.

Site	Sector	Size	Exposure	Expected tier
Site 1	Law firm	Under 15 attorneys	A: AI drafting and research	Tier 1
Site 2	Healthcare nonprofit	40 to 80 staff	B: ambient documentation, patient-facing chatbot	Tier 2
Site 3	Financial services	Under 100 staff	C: AI-assisted eligibility or intake scoring	Tier 3

5.3 Procedure

For each site: apply the placement rule with leadership; stand up the tier's controls using the templates; record effort in hours by role; conduct a mock audit walkthrough against the crosswalk; interview the accountable owner on clarity, burden, and confidence. Iterate the artifact on what broke.

5.4 Reporting

Report per site: hours to stand up, controls performed versus template controls, mock audit findings, and owner-reported confidence. Report across sites: which controls needed rewording, where the placement rule was ambiguous, and where the sector column of the crosswalk was insufficient. Pilot organizations are anonymized and written consent obtained; IRB review is expected to be exempt but should be confirmed.

- ☐ Recruit three volunteer pilot sites matching the target profiles
- ☐ Confirm IRB exemption
- ☐ Draft interview protocol for accountable owners

6. Discussion: measurement, verification, and limitations

6.1 From proportionate to measurable

The model states what an organization does. It does not yet score how well. A readiness instrument scoring each control area on presence, evidence quality, and currency would let an organization track its posture over time and let a regulator, insurer, or partner compare organizations at the same tier. This is a natural extension and a candidate for the author's existing work on assessment instruments.

6.2 From assertion to verification

At every tier the model still relies on the organization asserting that it performs its controls. The author's related work on zero-knowledge proofs in enterprise AI governance ("From Trust by Assertion to Trust by Verification," NABET 2026) addresses the enterprise case, where an organization proves compliance

properties without exposing internals. The small-organization version of that problem is real: a Tier 2 nonprofit that must demonstrate its AI documentation practices to a hospital partner, or a Tier 3 lender demonstrating fairness testing to a regulator, currently does so by handing over documents. A verifiable attestation layer sized for small organizations is future work, and the tier structure here is a prerequisite for it because verification requires a defined claim to verify.

6.3 Limitations

- The three-tier structure is a simplification. Some organizations will straddle tiers by use case; the model handles this by placing the organization at the highest applicable tier, which may over-burden a mostly Exposure A organization with one Exposure C use case. A per-use-case variant is possible but trades simplicity for precision.
- The sector column of the crosswalk is illustrative and jurisdiction-dependent. It will require updating at each revision.
- Validation across three sites establishes usability, not generalizability. Broader validation through a practitioner survey is a logical next step.
- The model assumes good faith. It does not prevent an organization from placing itself at a lower tier than its exposure warrants. The placement rule is designed to make that misplacement obvious to an auditor, not to prevent it.

7. Conclusion

Small regulated organizations do not need less AI governance than large ones. They need governance sized to what their AI does and staffed by whoever is there. The Proportionate Governance Model provides that: a placement rule driven by exposure, three cumulative tiers each with a minimum viable control set and named evidence, and a crosswalk that lets an organization state its coverage honestly against the frameworks its auditors, regulators, and insurers recognize. The baseline tier is implementable by one non-technical person in about a week, which is the difference between a policy that exists and one that is performed. The model's premise, that trust in AI should rest on what an organization can show rather than what it asserts, scales down as well as it scales up.

Appendix A: Tier 1 Acceptable Use Policy template

This template is the complete Tier 1 policy. It is written to be adopted as-is by an organization at Exposure A, with bracketed fields completed by the AI owner. It states only controls a Tier 1 organization performs. Do not add controls from this template's higher-tier siblings unless the organization will actually operate them.

Artificial Intelligence Acceptable Use Policy

****Organization:**** [Organization name]

****AI Owner:**** [Name, title]

****Effective date:**** [Date]

****Next review:**** [Date, 12 months out]

****Tier:** 1 (Baseline).** This policy covers AI used for drafting, summarizing, research, and similar productivity tasks where a person reviews every output before it is used or shared.

1. Purpose

This policy sets the rules for using artificial intelligence tools at [Organization]. It exists so that staff can use AI productively without exposing client, patient, or organizational information, and so that [Organization] can show clients, regulators, and insurers how AI use is governed.

2. Scope

This policy applies to all staff, contractors, and volunteers who use AI tools for [Organization] work on any device. AI tools include chat assistants, drafting and writing assistants, AI features inside office software, transcription and summarization tools, and any service that generates or transforms content using AI.

3. Approved tools

Only tools listed in the AI Tool Inventory (Attachment 1) may be used for [Organization] work. The AI Owner approves additions. Staff may request a tool be added by contacting the AI Owner; do not use it until it appears on the inventory.

4. Information that must never be entered into an AI tool

Unless the inventory specifically lists a tool as approved for that data type, do not enter:

- Client or patient names, identifiers, or any information that could identify them
- Protected health information (PHI) or medical details
- Attorney-client privileged or work product material
- Social Security numbers, financial account numbers, or payment card numbers
- Passwords, credentials, or security configuration details
- Personnel records, salary information, or performance evaluations

- Any information covered by a confidentiality agreement or court order

When in doubt, remove or replace identifying details before using the tool, or ask the AI Owner.

5. Human review

No AI-generated or AI-assisted content leaves [Organization], is sent to a client or patient, is filed, or is relied on for a decision until a qualified person has reviewed it for accuracy, completeness, and appropriateness. The reviewer is responsible for the content as if they had written it. AI tools can produce confident, incorrect, or fabricated information, including false citations and invented facts.

6. Disclosure

[Choose one and delete the other.]

Option A: Staff will disclose the use of AI tools when a client, patient, court, regulator, or funder asks, and where professional rules or contracts require it.

Option B: [Organization] discloses AI assistance in [specify: engagement letters / intake forms / published work] using the following language: "[Organization] may use AI tools to assist with drafting and research. All work is reviewed by [a licensed professional / qualified staff] before delivery."

7. Responsibilities

****AI Owner:**** maintains the tool inventory, approves tools, confirms each tool's data retention and training-use terms before approval and keeps a dated copy, conducts the annual self-assessment, arranges training, and reviews this policy annually.

****All staff:**** use only approved tools, follow the data rules in Section 4, review AI output before use, complete required training, and report concerns or mistakes promptly.

8. Training

All staff complete a 30-minute AI orientation at onboarding and an annual refresher. Attendance is recorded by the AI Owner.

9. Reporting problems

Report any of the following to the AI Owner as soon as possible: restricted information entered into an AI tool by mistake, an AI output that was relied on and turned out to be wrong, use of an unapproved tool, or any client or patient concern about AI use. Reports are handled through [Organization]'s existing [incident / HR / compliance] process. Reporting a mistake in good faith will not itself result in discipline.

10. Review

The AI Owner reviews this policy and the tool inventory annually and whenever [Organization] adopts AI for a new purpose, especially any use that produces content seen by clients or patients or that informs decisions about individuals. Such a change may move [Organization] to a higher governance tier.

Attachment 1: AI Tool Inventory

Tool	Approved for	Data it may see	Retention and training terms confirmed (date)	Approved by
---	---	---	---	---
[Tool]	[Drafting / research / summarization]	[Public / internal only / none of Section 4]	[Date]	[Name]

Attachment 2: Annual Self-Assessment

Answer yes or no. Any "no" becomes an action item with an owner and date.

1. Is the AI Tool Inventory current?
2. Has each tool's data retention and training-use term been confirmed in the past 12 months?
3. Have all staff completed AI training in the past 12 months?

4. Has every reported AI problem been logged and addressed?
5. Has any AI use started producing content seen by clients or patients?
6. Has any AI use started informing decisions about individuals?
7. Are there tools in use that are not on the inventory?
8. Has the AI Owner changed, and if so, is this policy updated?
9. Have any contracts, insurers, or regulators asked about AI use, and were they answered from this policy?
10. Is the next review date set?

A "yes" to questions 5 or 6 requires reassessment of tier placement.

How to use this template

An organization at Exposure A should be able to complete the bracketed fields, fill Attachment 1 for its current tools, and run Attachment 2 once within about five working hours. The dated copies of vendor terms, the training attendance record, and the completed self-assessment are the audit evidence for Tier 1. That is the entire Tier 1 evidence set.

References (working list)

Full citations to be completed and verified before submission. Listed by the section that relies on them.

Frameworks and standards

- National Institute of Standards and Technology. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. Also the companion *AI RMF Playbook*.
- International Organization for Standardization. (2023). *ISO/IEC 42001:2023 Information technology, Artificial intelligence, Management system*.
- ISACA. (2018). *COBIT 2019 Framework: Governance and Management Objectives*.
- European Parliament and Council. (2024). Regulation (EU) 2024/1689 (Artificial Intelligence Act).

Sector expectations

- American Bar Association Standing Committee on Ethics and Professional Responsibility. (2024). *Formal Opinion 512: Generative Artificial Intelligence Tools*.
- U.S. Department of Health and Human Services. HIPAA Security Rule, 45 CFR Part 164, Subpart C.
- Colorado General Assembly. (2024). SB 24-205, Consumer Protections for Artificial Intelligence (confirm current effective date and amendments).
- New York City Local Law 144 of 2021, Automated Employment Decision Tools.
- National Association of Insurance Commissioners. (2023). *Model Bulletin: Use of Artificial Intelligence Systems by Insurers*.

- Office of the Comptroller of the Currency, Federal Reserve, FDIC. (2023). *Interagency Guidance on Third-Party Relationships: Risk Management*.
- Federal Trade Commission. Standards for Safeguarding Customer Information (GLBA Safeguards Rule), 16 CFR Part 314.

Method

- Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75 to 105.
- Peffers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems*, 24(3), 45 to 77.

Author's related work

- Mangle, A. H. (2026, October). *From trust by assertion to trust by verification: Zero-knowledge proofs in enterprise AI governance*. Paper presented at the NABET 2026 Conference, Harrisburg, PA.

To locate

- Small-business AI adoption statistics (U.S. Census Bureau Business Trends and Outlook Survey AI supplement, or comparable) for Section 1
- Literature on AI governance in SMEs, if any exists in IS journals, for positioning the contribution
- Cyber insurance questionnaire examples referencing AI use, for Section 1